

WYDZIAŁ INFORMATYKI I TELEKOMUNIKACJI
Instytut Informatyki

Praca dyplomowa magisterska

**ANALIZA RUCHU SIECIOWEGO APLIKACJI MOBILNYCH NA
PLATFORMIE ANDROID**

Mikołaj Kmiecik, nr albumu 147575

Promotor
dr inż. dr inż. Michał Kalewski

POZNAŃ 2025

Streszczenie

Przedmiotem pracy jest analiza ruchu sieciowego generowanego przez wybrane aplikacje mobilne systemu Android. Zaimplementowano środowisko przechwytywania (mitmproxy, tcpdump), normalizacji i klasyfikacji z uwzględnieniem protokołów (HTTP/1.1, HTTP/2, QUIC), szyfrowania TLS oraz aspektów prywatności (domeny trackingowe, identyfikatory). Wyniki obejmują statystyki protokołów, charakterystykę ruchu według kategorii aplikacji oraz ocenę ryzyk potencjalnego ujawniania metadanych.

Słowa kluczowe: Android, analiza ruchu, TLS, QUIC, prywatność, mitmproxy.

Abstract

This thesis investigates network traffic generated by selected Android applications. A modular environment for traffic interception (mitmproxy, tcpdump), normalization and classification was implemented, focusing on protocols (HTTP/1.1, HTTP/2, QUIC), TLS encryption and privacy aspects (tracking domains, identifiers). Results include protocol usage statistics, traffic characteristics across app categories, and an assessment of potential metadata exposure risks.

Keywords: Android, network traffic analysis, TLS, QUIC, privacy, mitmproxy.

Spis treści

0.1	Instagram (wersja 394.0.0.46.81)	5
0.1.1	Wolumen i liczność wg protokołu	5
0.1.2	Największe cele (IP/port) wg wolumenu	6
0.1.3	Najczęstsze hosty (liczba przepływów)	6
0.1.4	Dodatkowe charakterystyki ruchu	6
0.1.5	Wyniki z Exodus Privacy (aplikacja)	7
0.1.6	Dyskusja i ograniczenia	7
0.1.7	Podsumowanie	7
1	Eksperyment: analiza ruchu aplikacji Facebook z użyciem PCAPdroid	9
1.1	Cel i założenia	9
1.2	Środowisko i narzędzia	9
1.3	Procedura (pojedyncza iteracja)	9
1.4	Zebrane dane (ta sesja)	9
1.5	Wyniki ilościowe	10
1.5.1	Wolumen i liczność wg protokołu	10
1.5.2	Największe cele (IP/port) wg wolumenu	10
1.5.3	Najczęstsze hosty (liczba przepływów)	10
1.6	Wyniki z Exodus Privacy (aplikacja)	11
1.7	Dyskusja i ograniczenia	11
1.8	Artefakty i replikowalność	11
1.9	Podsumowanie	11
2	Eksperymenty: studia przypadków (PCAPdroid + Exodus)	13
2.1	Cel i założenia	13
2.2	Procedura (pojedyncza iteracja)	13
2.3	Instagram (wersja 394.0.0.46.81)	13
2.3.1	Wolumen i liczność wg protokołu	14
2.3.2	Największe cele (IP/port) wg wolumenu	14
2.3.3	Najczęstsze hosty (liczba przepływów)	14
2.4	Obserwacje jakościowe	15
2.4.1	Wyniki z Exodus Privacy (aplikacja)	15
2.4.2	Dyskusja i ograniczenia	15
2.4.3	Podsumowanie	16
2.5	Facebook (wersja 526.1.0.66.75)	16
2.5.1	Wolumen i liczność wg protokołu	16
2.5.2	Największe cele (IP/port) wg wolumenu	16
2.5.3	Najczęstsze hosty (liczba przepływów)	17

2.5.4	Wyniki z Exodus Privacy (aplikacja)	17
2.5.5	Dyskusja i ograniczenia	17
2.5.6	Podsumowanie	17
3	Eksperyment: analiza ruchu aplikacji Instagram z użyciem PCAPdroid	19
3.1	Cel i założenia	19
3.2	Środowisko i narzędzia	19
3.3	Procedura (pojedyncza iteracja)	19
3.4	Zebrane dane (ta sesja)	20
3.5	Wyniki ilościowe	20
3.5.1	Wolumen i liczność wg protokołu	20
3.5.2	Największe cele (IP/port) wg wolumenu	20
3.6	Obserwacje jakościowe	20
3.7	Dyskusja i ograniczenia	21
3.8	Wariant porównawczy (HTTP/3 → HTTP/2)	21
3.9	Artefakty i replikowalność	21
3.10	Podsumowanie	21
	Bibliografia	23

0.1 Instagram (wersja 394.0.0.46.81)

Okno i wolumen

Okno eksperymentu: **2025-08-18 17:55:47–18:08:00** (≈ 12.2 min). Zarejestrowano **302** przepływy, wolumen $\approx$ **28.04 MiB** (**RX** $\approx$ **27.20 MiB**, **TX** $\approx$ **0.85 MiB**). Stosunek RX/TX wyniósł $\approx 32:1$, co wskazuje, że w badanej sesji użytkownik głównie konsumował treści, a nie je publikował.

0.1.1 Wolumen i liczność wg protokołu

TABELA 0.1: Podsumowanie wg protokołu (Instagram, ta sesja)

Protokół	Flows	MiB (total)	B wysłane	B odebrane
QUIC	187	27.99	855,220	28,500,436
HTTPS	5	0.02	12,180	9,063
TCP	12	0.02	15,384	3,699
DNS	49	0.00	1,475	2,441
TLS	36	0.00	2,160	1,440
UDP	5	0.00	837	346
HTTP	8	0.00	480	320
Razem	302	28.04	888,736	28,517,745

Obserwacja: Ruch Instagrama jest jeszcze silniej zdominowany przez QUIC/HTTP/3 niż w przypadku Facebooka (99,8% wolumenu vs. 98,5%).

TABELA 0.2: Udział protokołów i portów (Instagram, liczba flow)

Protokół / Port	Flows	% flows
QUIC	187	61.9%
DNS	49	16.2%
TLS	36	11.9%
TCP	12	4.0%
HTTP	8	2.6%
HTTPS	5	1.7%
UDP	5	1.7%
Port 443 (HTTPS/QUIC)	233	77.1%
Port 53 (DNS)	49	16.2%
Port 5222 (TCP)	12	4.0%
Port 80 (HTTP)	8	2.6%

0.1.2 Największe cele (IP/port) wg wolumenu

TABELA 0.3: Największe kierunki ruchu (Instagram, ta sesja)

IP docelowe	Port	Proto	Flows	MiB
185.60.217.63	443	QUIC	137	27.52
157.240.251.63	443	QUIC	1	0.33
185.60.217.3	443	QUIC	35	0.08
185.60.217.20	443	QUIC	2	0.02
185.60.217.175	5222	TCP	11	0.02
157.240.251.11	443	QUIC	1	0.02
185.60.217.28	443	QUIC	1	0.01
157.240.0.63	443	QUIC	1	0.01
185.60.217.13	443	HTTPS	2	0.01
157.240.253.17	443	HTTPS	1	0.01

Obserwacja: Największy wolumen koncentruje się na adresie 185.60.217.63 (serwer Meta, Dublin), co sugeruje wykorzystanie pobliskich CDN. Występują też długotrwałe połączenia TCP/5222 (port MQTT) do 185.60.217.175, związane z powiadomieniami/czatem.

0.1.3 Najczęstsze hosty (liczba przepływów)

TABELA 0.4: Top hosty (Instagram, liczba przepływów)

Host	Flows
graph.instagram.com	138
gateway.instagram.com	64
z-p42-chat-e2ee-ig.facebook.com	35
edge-mqtt.facebook.com	17
i.instagram.com	10
graph.facebook.com	5
i-fallback.instagram.com	5
scontent-ber1-1.cdninstagram.com	2
static.xx.fbcdn.net	2
lookaside.facebook.com	1

Obserwacja: Widoczna jest silna integracja z infrastrukturą Meta: poza domenami instagrama (graph, gateway, i.instagram.com) występują też hosty facebookowe (edge-mqtt, graph.facebook.com, lookaside).

0.1.4 Dodatkowe charakterystyki ruchu

- **Rozkład w czasie:** ruch miał charakter burstowy podczas aktywnego scrollowania feedu, natomiast po przejściu aplikacji do tła obserwowano niską, ale stałą aktywność (MQTT keep-alive).
- **Asymetria protokołów:** QUIC odpowiadał prawie wyłącznie za download (RX), natomiast TCP/5222 (MQTT) miał bardziej zbalansowany stosunek RX/TX.
- **Czas trwania przepływów:** połączenia QUIC były krótkotrwałe, natomiast MQTT utrzymywało stabilne sesje kilkuminutowe — co odpowiada architekturze powiadomień.
- **Fallback:** w sesji pojawiły się adresy i-fallback.instagram.com, co wskazuje na stosowanie alternatywnych ścieżek w przypadku problemów z podstawowym API.

- **Geolokalizacja IP:** dominują adresy należące do Meta Platforms Ireland Ltd. (185.60.217.*), co sugeruje lokalne routowanie dla użytkownika w Europie.

0.1.5 Wyniki z Exodus Privacy (aplikacja)

Metoda. *Exodus Privacy* raport dla `com.instagram.android` (wersja 394.0.0.46.81) wykazał obecność **4 trackerów** oraz **69 uprawnień**.

Trackery.

- Facebook Flipper (analiza, debugging),
- Facebook Login (identyfikacja konta),
- Facebook Notifications,
- Google Analytics.

Uprawnienia — kategorie kluczowe:

- **Lokalizacja:** `ACCESS_FINE_LOCATION`, `ACCESS_MEDIA_LOCATION`,
- **Multimedia:** `CAMERA`, `RECORD_AUDIO`, `READ/WRITE_EXTERNAL_STORAGE`, `READ_MEDIA_IMAGES/VIDEO`,
- **Tożsamość/konta/telefon:** `GET_ACCOUNTS`, `READ_CONTACTS`, `READ_CALL_LOG`, `READ_PHONE_STATE`, `ANSWER_PHONE_CALLS`,
- **Sieć i praca w tle:** `ACCESS_NETWORK_STATE`, `WAKE_LOCK`, `RECEIVE_BOOT_COMPLETED`, `FOREGROUND_SERVICE`.

Uwaga: pełna lista 69 uprawnień znajduje się w raporcie Exodusa (załącznik PDF/HTML).

0.1.6 Dyskusja i ograniczenia

Obserwowalność treści. Podobnie jak w przypadku Facebooka, dominacja QUIC/HTTP/3 (99,8% wolumenu) uniemożliwia analizę zawartości HTTP; możliwa jest jedynie analiza metadanych (hosty, czasy, wolumeny).

Zmienność wersji. Instagram jest aplikacją o wysokiej dynamice wydawniczej. Udział QUIC, hosty i zestaw uprawnień mogą różnić się między wersjami i regionami. Wyniki dotyczą wersji 394.0.0.46.81.

0.1.7 Podsumowanie

W badanej sesji Instagram wykazuje:

1. niemal całkowitą dominację QUIC/HTTP/3 w wolumenie (99,8%),
2. silną integrację z infrastrukturą Meta (występowanie hostów facebookowych obok instagramowych),
3. asymetrię RX/TX (27.2 vs 0.85 MiB), wskazującą na konsumpcję treści,
4. różne wzorce protokołów: krótkie sesje QUIC (content delivery) vs długie sesje MQTT (utrzymanie czatu/powiadomień),
5. bogaty zestaw uprawnień aplikacji (69) obejmujących lokalizację, multimedia, kontakty i telefon, oraz obecność 4 trackerów.

Rozdział 1

Eksperyment: analiza ruchu aplikacji Facebook z użyciem PCAPdroid

1.1 Cel i założenia

Celem eksperymentu jest empiryczna charakterystyka komunikacji sieciowej aplikacji **Facebook** (`com.facebook.katana`) oraz zestawienie obserwacji z danymi o uprawnieniach i trackerach (metodologia *Exodus Privacy*). Interesują nas:

1. wykorzystywane protokoły i transport (HTTP/1.1, HTTP/2, HTTP/3/QUIC, TLS),
2. wzorce zachowania (piki aktywności vs. praca w tle),
3. rozproszenie docelowych usług (IP/port/host),
4. ograniczenia obserwowalności wynikające z QUIC/HTTP/3 i ewentualnego *certificate pinning*.

1.2 Środowisko i narzędzia

- Urządzenie z Androidem, konto testowe; sieć laboratoryjna (AP na Linuxie).
- **PCAPdroid**: lokalny VPN (bez roota), zapis do CSV/`pcapng`; filtrowanie po *Facebook*.
- Analiza: agregacje z CSV (pakiety/bajty/proto/host), weryfikacja w Wireshark/tshark; interpretacja protokołów (ALPN, QUIC/UDP 443).

1.3 Procedura (pojedyncza iteracja)

Jedna iteracja (12,3 min) składała się z: (1) zimnego startu i krótkiej nawigacji (feed, profil, wyszukiwanie), (2) krótkiej interakcji multimedialnej, (3) przejścia do tła i obserwacji w tle. Szczegóły i uzasadnienia czasów — patrz Rozdz. ??.

1.4 Zebrane dane (ta sesja)

Okno eksperymentu: **2025-08-19 19:24:12–19:36:29** (12.28 min). Zarejestrowano **305** przepływów (*flows*) o łącznym wolumenie **29.75 MiB**; **RX 28.30 MiB**, **TX 1.45 MiB**.

1.5 Wyniki ilościowe

1.5.1 Wolumen i liczność wg protokołu

TABELA 1.1: Podsumowanie wg protokołu (Facebook, ta sesja)

Protokół	Flows	% flows	MiB	% wolumenu
QUIC	132	43,3%	29.29	98,5%
TLS	93	30,5%	0.01	0,0%
DNS	46	15,1%	0.00	0,0%
HTTPS	19	6,2%	0.43	1,5%
TCP	10	3,3%	0.01	0,0%
HTTP	5	1,6%	0.00	0,0%
Razem	305	100%	29.75	100%

1.5.2 Największe cele (IP/port) wg wolumenu

TABELA 1.2: Największe kierunki ruchu (Facebook, ta sesja)

IP docelowe	Port	Proto	Flows	MiB
185.60.217.28	443	QUIC	50	25.46
157.240.210.14	443	QUIC	1	2.01
185.60.217.20	443	QUIC	79	1.79
185.60.217.3	443	HTTPS	2	0.20
157.240.210.16	443	HTTPS	8	0.15
157.240.210.3	443	HTTPS	3	0.03
185.60.217.13	443	HTTPS	2	0.02
185.60.217.28	443	HTTPS	1	0.02
157.240.0.13	443	QUIC	1	0.01
31.13.91.40	443	QUIC	1	0.01

1.5.3 Najczęstsze hosty (liczba przepływów)

TABELA 1.3: Top hosty (Facebook, liczba przepływów)

Host	Flows
graph.facebook.com	85
lookaside.facebook.com	54
chat-e2ee-mini.facebook.com	25
gateway.instagram.com	24
gateway.facebook.com	19
edge-mqtt.facebook.com	14
graph-fallback.facebook.com	14
gateway-fallback.facebook.com	9
edge-mqtt-fallback.facebook.com	2
*.fbcdn.net (różne)	5

Obserwacje:

- **Dominacja QUIC/HTTP/3:** niemal cały wolumen (98,5%) to QUIC na 443/UDP; obecne są też śladowe HTTPS/TCP na 443 (np. fallback, zasoby pomocnicze).
- **Kanały usługowe:** widoczne hosty typu edge-mqtt.facebook.com, gateway.facebook.com/instagram.com (utrzymanie sesji, powiadomienia, API graficzne).

- **Wzorzec ruchu:** wyraźny *burst* około 19:26 (większość nowych i kończących się flow), po czym aktywność w tle spada do sporadycznych wywołań.

1.6 Wyniki z Exodus Privacy (aplikacja)

Metoda. *Exodus Privacy* wykonuje statyczną analizę pakietu APK i raportuje wykryte biblioteki śledzące (trackery) oraz zadeklarowane uprawnienia aplikacji. Wnioski z takiej analizy należy zestawiać z obserwacjami dynamicznymi z ruchu sieciowego (PCAPdroid), co robimy w niniejszej pracy.

Uprawnienia — kategorie kluczowe. Dla Facebooka istotne z perspektywy prywatności są zwłaszcza:

- **Lokalizacja:** ACCESS_FINE_LOCATION, ACCESS_COARSE_LOCATION (precyzyjna/przybliżona lokacja).
- **Multimedia:** CAMERA, RECORD_AUDIO, dostęp do pamięci (READ/WRITE_EXTERNAL_STORAGE — jeśli występują w używanej wersji).
- **Tożsamość/konta/książka adresowa:** GET_ACCOUNTS, READ_CONTACTS.
- **Sieć/telefon i praca w tle:** ACCESS_NETWORK_STATE, WAKE_LOCK, RECEIVE_BOOT_COMPLETED.

Uwaga: dokładny zestaw i liczba uprawnień zależą od wersji aplikacji i kanału dystrybucji; w raporcie Exodusa dla `com.facebook.katana` należy je cytować dla konkretnej wersji aplikacji poddanej badaniu.

Trackery. Raporty Exodusa wskazują obecność/nieobecność znanych bibliotek śledzących na podstawie reguł detekcji kodu/sieci. Wartościowe jest porównanie z hostami z Tabeli 2.6 (np. korespondencja *Audience/Analytics* ↔ `graph.facebook.com`, `fbcdn.net`).

1.7 Dyskusja i ograniczenia

Obserwowalność treści. Transport QUIC/UDP ogranicza klasyczne MITM/TLS-over-TCP; wgląd w semantykę HTTP jest bardzo ograniczony, dlatego opieramy się na metadanych (hosty, czasy, wolumeny) i korelacji zachowań.

Zmienność wersji. Facebook to aplikacja o wysokiej dynamice wydawniczej; zestaw hostów, udział QUIC/H2 oraz uprawnienia mogą różnić się między wersjami i regionami. Liczby w tym rozdziale odnoszą się do konkretnej sesji i wersji aplikacji użytej w eksperymencie.

1.8 Artefakty i replikowalność

Udostępniamy CSV/PCAPNG z sesji (nazewnictwo: `YYYYMMDD_HHMM_Facebook_runN_net=default_vApp_vAnd`) oraz skrypty agregujące. W przypadku sekcji *Exodus Privacy* zaleca się dołączenie PDF/HTML raportu dla użytej wersji `com.facebook.katana`.

1.9 Podsumowanie

W badanej sesji Facebook wykazuje: (i) dominację QUIC/HTTP/3 w wolumenie (98,5%), (ii) charakterystyczne kanały usługowe (`graph/gateway/edge-mqtt`), (iii) krótkotrwałe piki transferów związane z interakcjami użytkownika oraz ograniczoną aktywność w tle. Z perspektywy

prywatności kluczowe są uprawnienia do lokalizacji, multimediiów i pracy w tle oraz obecność komponentów analityczno-reklamowych — ich interpretację należy zawsze osadzać w kontekście wersji aplikacji i potwierdzać obserwacjami dynamicznymi.

Rozdział 2

Eksperymenty: studia przypadków (PCAPdroid + Exodus)

2.1 Cel i założenia

Celem eksperymentu jest empiryczna charakterystyka komunikacji sieciowej wybranych aplikacji oraz zestawienie obserwacji z danymi o uprawnieniach i trackerach (metodologia *Exodus Privacy*). Interesują nas:

1. rejestracja ruchu z użyciem **PCAPdroid** (tryb VPN, eksport CSV/PCAPNG),
2. agregacja metryk (protokół, host, port, wolumen),
3. korelacja z analizą statyczną **Exodus Privacy** (trackery i uprawnienia).

2.2 Procedura (pojedyncza iteracja)

Zgodnie z metodyką, jedna iteracja (≈ 15 min) składa się z:

1. **Baseline OS (2 min)** – app nieuruchomiona; punkt odniesienia dla tła.
2. **Cold start (1 min)** – uruchomienie i ustabilizowanie ekranu głównego.
3. **Nawigacja (2 min)** – główne ekrany (feed, profil, wyszukiwarka).
4. **Media/operacja (1 min)** – krótkie odtwarzanie/przewijanie, wymuszenie większych transferów.
5. **Offline/online (4 min)** – 2 min offline + 2 min po reconnect; obserwacja retry/backoff.
6. **Tło (10 min)** – obserwacja po zamknięciu aplikacji.

2.3 Instagram (wersja 394.0.0.46.81)

Okno i wolumen

Okno eksperymentu: **2025-08-18 17:55:47–18:08:00** (≈ 12.2 min). Zarejestrowano **302** przepływy, wolumen $\approx$ **28.04 MiB** (RX $\approx$ **27.20 MiB**, TX $\approx$ **0.85 MiB**).

2.3.1 Wolumen i liczność wg protokołu

TABELA 2.1: Podsumowanie wg protokołu (Instagram, ta sesja)

Protokół	Flows	MiB (total)	B wysłane	B odebrane
QUIC	187	27.99	855,220	28,500,436
HTTPS	5	0.02	12,180	9,063
TCP	12	0.02	15,384	3,699
DNS	49	0.00	1,475	2,441
TLS	36	0.00	2,160	1,440
UDP	5	0.00	837	346
HTTP	8	0.00	480	320
Razem	302	28.04	888,736	28,517,745

Obserwacja: Ruch Instagrama jest silnie zdominowany przez QUIC/HTTP/3.

2.3.2 Największe cele (IP/port) wg wolumenu

TABELA 2.2: Największe kierunki ruchu (Instagram, ta sesja)

IP docelowe	Port	Proto	Flows	MiB
185.60.217.63	443	QUIC	137	27.52
157.240.251.63	443	QUIC	1	0.33
185.60.217.3	443	QUIC	35	0.08
185.60.217.20	443	QUIC	2	0.02
185.60.217.175	5222	TCP	11	0.02
157.240.251.11	443	QUIC	1	0.02
185.60.217.28	443	QUIC	1	0.01
157.240.0.63	443	QUIC	1	0.01
185.60.217.13	443	HTTPS	2	0.01
157.240.253.17	443	HTTPS	1	0.01

Obserwacja: Największy wolumen koncentruje się na adresie 185.60.217.63 (serwer Meta, Dublin), co sugeruje wykorzystanie pobliskich CDN. Występują też długotrwałe połączenia TCP/5222 (port MQTT) do 185.60.217.175, związane z powiadomieniami/czatem.

2.3.3 Najczęstsze hosty (liczba przepływów)

TABELA 2.3: Top hosty (Instagram, liczba przepływów)

Host	Flows
graph.instagram.com	138
gateway.instagram.com	64
z-p42-chat-e2ee-ig.facebook.com	35
edge-mqtt.facebook.com	17
i.instagram.com	10
graph.facebook.com	5
i-fallback.instagram.com	5
scontent-ber1-1.cdninstagram.com	2
static.xx.fbcdn.net	2
lookaside.facebook.com	1

Obserwacja: Widoczna jest silna integracja z infrastrukturą Meta: poza domenami instagrama (graph, gateway, i.instagram.com) występują też hosty facebookowe (edge-mqtt, graph.facebook.com, lookaside).

2.4 Obserwacje jakościowe

- **Dominacja HTTP/3/QUIC.** Zdecydowana większość ruchu (liczebnie i wolumenowo) to QUIC na 443/UDP, co jest zgodne z trendem migracji warstwy mediów do HTTP/3 [1], [3].
- **Kanał utrzymania sesji.** Występuje równoległy kanał na **TCP/5222** (11–12 flows, mały wolumen), prawdopodobnie do komunikacji w czasie rzeczywistym/utrzymania połączenia.
- **Burst podczas interakcji, potem „oddech”.** Zliczenia per minuta (niezamieszczone tu dla zwięzłości) pokazują silny pik około 17:59 (setki nowych/kończących się flow), po którym następują krótkie sekwencje aktywności w tle (18:05–18:06).
- **Niewielki ślad HTTP/1.1/HTTPS.** Jedynie kilka żądań; główna komunikacja i zasoby idą ścieżką QUIC.

2.4.1 Wyniki z Exodus Privacy (aplikacja)

Metoda. *Exodus Privacy* raport dla com.instagram.android (wersja 394.0.0.46.81, źródło Google Play) wykazał obecność **4 trackerów** oraz **69 uprawnień**.

Trackery.

- Facebook Flipper (analytics),
- Facebook Login (identification),
- Facebook Notifications,
- Google Analytics (analytics).

Uprawnienia — przykłady kluczowe:

- **Lokalizacja:** ACCESS_FINE_LOCATION, ACCESS_MEDIA_LOCATION,
- **Multimedia:** CAMERA, RECORD_AUDIO, READ/WRITE_EXTERNAL_STORAGE, READ_MEDIA_IMAGES/VIDEO,
- **Tożsamość/konta/telefon:** GET_ACCOUNTS, READ_CONTACTS, READ_CALL_LOG, READ_PHONE_STATE, ANSWER_PHONE_CALLS,
- **Sieć i praca w tle:** ACCESS_NETWORK_STATE, WAKE_LOCK, RECEIVE_BOOT_COMPLETED, FOREGROUND_SERVICE_*.

Uwaga: pełna lista 69 uprawnień znajduje się w raporcie Exodusa (załącznik PDF/HTML).

2.4.2 Dyskusja i ograniczenia

Obserwowalność treści. Podobnie jak w przypadku Facebooka, dominacja QUIC/HTTP/3 (99,8% wolumenu) mocno ogranicza możliwość wglądu w treść ruchu.

Zmienność wersji. Instagram, podobnie jak Facebook, jest często aktualizowany. Hosty, udział QUIC i zestaw uprawnień mogą różnić się między wersjami i regionami. Wyniki dotyczą wersji 394.0.0.46.81.

2.4.3 Podsumowanie

W badanej sesji Instagram wykazuje:

1. niemal całkowitą dominację QUIC/HTTP/3 w wolumenie (99,8%),
2. intensywne użycie hostów `graph.instagram.com`, `gateway.instagram.com`, `chat-e2ee` (komunikacja, API, czat),
3. asymetrię RX/TX (27.2 vs 0.85 MiB) – użytkownik konsumował treści,
4. szerokie spektrum uprawnień (w tym lokalizacja, multimedia, telefonia) i obecność trackerów analitycznych.

2.5 Facebook (wersja 526.1.0.66.75)

Okno i wolumen

Okno eksperymentu: **2025-08-19 19:24:12–19:36:29** (≈ 12.28 min). Zarejestrowano **305** przepływów, wolumen $\approx$ **29.75 MiB** (RX $\approx$ **28.30 MiB**, TX $\approx$ **1.45 MiB**).

2.5.1 Wolumen i liczność wg protokołu

TABELA 2.4: Podsumowanie wg protokołu (Facebook, ta sesja)

Protokół	Flows	% flows	MiB	% wolumenu
QUIC	132	43,3%	29.29	98,5%
TLS	93	30,5%	0.01	0,0%
DNS	46	15,1%	0.00	0,0%
HTTPS	19	6,2%	0.43	1,5%
TCP	10	3,3%	0.01	0,0%
HTTP	5	1,6%	0.00	0,0%
Razem	305	100%	29.75	100%

2.5.2 Największe cele (IP/port) wg wolumenu

TABELA 2.5: Największe kierunki ruchu (Facebook, ta sesja)

IP docelowe	Port	Proto	Flows	MiB
185.60.217.28	443	QUIC	50	25.46
157.240.210.14	443	QUIC	1	2.01
185.60.217.20	443	QUIC	79	1.79
185.60.217.3	443	HTTPS	2	0.20
157.240.210.16	443	HTTPS	8	0.15
157.240.210.3	443	HTTPS	3	0.03
185.60.217.13	443	HTTPS	2	0.02
185.60.217.28	443	HTTPS	1	0.02
157.240.0.13	443	QUIC	1	0.01
31.13.91.40	443	QUIC	1	0.01

2.5.3 Najczęstsze hosty (liczba przepływów)

TABELA 2.6: Top hosty (Facebook, liczba przepływów)

Host	Flows
graph.facebook.com	85
lookaside.facebook.com	54
chat-e2ee-mini.facebook.com	25
gateway.instagram.com	24
gateway.facebook.com	19
edge-mqtt.facebook.com	14
graph-fallback.facebook.com	14
gateway-fallback.facebook.com	9
edge-mqtt-fallback.facebook.com	2
*.fbcdn.net (różne)	5

2.5.4 Wyniki z Exodus Privacy (aplikacja)

Metoda. *Exodus Privacy* wykonuje statyczną analizę pakietu APK i raportuje wykryte biblioteki śledzące (trackery) oraz zadeklarowane uprawnienia aplikacji. Wnioski z takiej analizy należy zestawiać z obserwacjami dynamicznymi z ruchu sieciowego (PCAPdroid), co robimy w niniejszej pracy.

Uprawnienia — kategorie kluczowe. Dla Facebooka istotne z perspektywy prywatności są zwłaszcza:

- **Lokalizacja:** ACCESS_FINE_LOCATION, ACCESS_COARSE_LOCATION (precyzyjna/przybliżona lokalizacja).
- **Multimedia:** CAMERA, RECORD_AUDIO, dostęp do pamięci (READ/WRITE_EXTERNAL_STORAGE — jeśli występują w używanej wersji).
- **Tożsamość/konta/książka adresowa:** GET_ACCOUNTS, READ_CONTACTS.
- **Sieć/telefon i praca w tle:** ACCESS_NETWORK_STATE, WAKE_LOCK, RECEIVE_BOOT_COMPLETED.

Uwaga: dokładny zestaw i liczba uprawnień zależą od wersji aplikacji i kanału dystrybucji; w raporcie Exodus dla `com.facebook.katana` należy je cytować dla konkretnej wersji aplikacji poddanej badaniu.

2.5.5 Dyskusja i ograniczenia

Obserwowalność treści. Transport QUIC/UDP ogranicza klasyczne MITM/TLS-over-TCP; wgląd w semantykę HTTP jest bardzo ograniczony.

Zmienność wersji. Facebook to aplikacja o wysokiej dynamice wydawniczej; zestaw hostów, udział QUIC/H2 oraz uprawnienia mogą różnić się między wersjami i regionami. Liczby w tym rozdziale odnoszą się do konkretnej sesji i wersji aplikacji użytej w eksperymencie.

2.5.6 Podsumowanie

W badanej sesji Facebook wykazuje:

1. dominację QUIC/HTTP/3 w wolumenie (98,5%),

2. charakterystyczne kanały usługowe (`graph/gateway/edge-mqtt`),
3. krótkotrwałe piki transferów związane z interakcjami użytkownika oraz ograniczoną aktywność w tle. Z perspektywy prywatności kluczowe są uprawnienia do lokalizacji, multimediów i pracy w tle oraz obecność komponentów analityczno-reklamowych.

Rozdział 3

Eksperyment: analiza ruchu aplikacji Instagram z użyciem PCAPdroid

3.1 Cel i założenia

Celem eksperymentu jest empiryczna charakterystyka komunikacji sieciowej popularnej aplikacji mobilnej (Instagram) pod kątem: (i) wykorzystywanych protokołów i transportu (HTTP/1.1, HTTP/2, HTTP/3/QUIC, TLS) [1], [3], [4], (ii) wzorców zachowania (bursty podczas interakcji vs. aktywność w tle), (iii) rozproszenia docelowych usług (domen/IP/portów) oraz (iv) ograniczeń obserwowalności wynikających z QUIC/HTTP/3 i ewentualnego *certificate pinning*. Rejestracji dokonano narzędziem PCAPdroid (no-root, tryb PCAPNG z kluczami) i poddano obróbce wg metodyki z Rozdz. ??; do inspekcji pcapng wykorzystywano również Wireshark [5].

3.2 Środowisko i narzędzia

- Urządzenie z Androidem, konto testowe; sieć laboratoryjna (AP na Linuxie).
- **PCAPdroid**: lokalny VPN (bez roota), *TLS Decryption* aktywne, zapis do .pcapng (z kluczami sesji).
- Analiza pcapng: Wireshark/tshark (ALPN, SNI, QUIC/UDP 443, identyfikacja HTTP/1.1/2/3) [1], [3], [5].

3.3 Procedura (pojedyncza iteracja)

Zgodnie z metodyką, jedna iteracja (15 min) składa się z:

1. **Baseline OS (2 min)** – app nieuruchomiona; punkt odniesienia dla tła.
2. **Cold start (1 min)** – uruchomienie i ustabilizowanie ekranu głównego.
3. **Nawigacja (2 min)** – główne ekrany (feed, profil, wyszukiwarka).
4. **Media/operacja (1 min)** – krótkie odtwarzanie/przewijanie, wymuszenie większych transferów.
5. **Offline/online (4 min)** – 2 min offline + 2 min po reconnect; obserwacja retry/backoff.
6. **Tło (10 min)** – obserwacja po zamknięciu aplikacji.

Motywacja czasów i uzasadnienia znajdują się w Rozdz. ???. QUIC/HTTP/3 (UDP) z natury ogranicza klasyczny MITM; analiza treści HTTP możliwa jest przede wszystkim w wariancie porównawczym z wymuszeniem *fallbacku* do HTTP/2/TCP (blokada UDP/443) [1].

3.4 Zebrane dane (ta sesja)

Eksperyment wykonano w dniu 2025-08-18 w oknie **17:56:33–18:10:14** (13.7 min). Zarejestrowano **302** przepływy (*flows*) o łącznym wolumenie **28.0 MiB**; **RX 27.2 MiB**, **TX 0.85 MiB**.

Udział protokołów (liczba flow): QUIC **61.9%**, DNS 16.2%, TLS 11.9%, TCP 4.0%, HTTP 2.6%, HTTPS 1.7%, UDP 1.7%. Dominującym portem docelowym był **443** (HTTPS/QUIC; 233 flow), dalej **53** (DNS; 49 flow), **5222** (TCP; 12 flow) i **80** (HTTP; 8 flow).

3.5 Wyniki ilościowe

3.5.1 Wolumen i liczność wg protokołu

TABELA 3.1: Podsumowanie wg protokołu (Instagram, ta sesja)

Protokół	Flows	MiB (total)	B wysłane	B odebrane
QUIC	187	27.99	855,220	28,500,436
HTTPS	5	0.02	12,180	9,063
TCP	12	0.02	15,384	3,699
DNS	49	0.00	1,475	2,441
TLS	36	0.00	2,160	1,440
UDP	5	0.00	837	346
HTTP	8	0.00	480	320
Razem	302	28.04	888,736	28,517,745

3.5.2 Największe cele (IP/port) wg wolumenu

TABELA 3.2: Największe kierunki ruchu (wolumen; Instagram, ta sesja)

IP docelowe	Port	Proto	Flows	MiB (total)
185.60.217.63	443	QUIC	137	27.52
157.240.251.63	443	QUIC	1	0.33
185.60.217.3	443	QUIC	35	0.08
185.60.217.20	443	QUIC	2	0.02
185.60.217.175	5222	TCP	11	0.02
157.240.251.11	443	QUIC	1	0.02
185.60.217.28	443	QUIC	1	0.01
157.240.0.63	443	QUIC	1	0.01
185.60.217.13	443	HTTPS	2	0.01
157.240.253.17	443	HTTPS	1	0.01

3.6 Obserwacje jakościowe

- **Dominacja HTTP/3/QUIC.** Zdecydowana większość ruchu (liczebnie i wolumenowo) to QUIC na 443/UDP, co jest zgodne z trendem migracji warstwy mediów do HTTP/3 [1], [3].

- **Kanał utrzymania sesji.** Występuje równoległy kanał na **TCP/5222** (11–12 flows, mały wolumen), prawdopodobnie do komunikacji w czasie rzeczywistym/utrzymania połączenia.
- **Burst podczas interakcji, potem „oddech”.** Zliczenia per minuta (niezamieszczone tu dla zwięzłości) pokazują silny pik około 17:59 (setki nowych/kończących się flow), po którym następują krótkie sekwencje aktywności w tle (18:05–18:06).
- **Niewielki ślad HTTP/1.1/HTTPS.** Jedynie kilka żądań; główna komunikacja i zasoby idą ścieżką QUIC.

3.7 Dyskusja i ograniczenia

Obserwowalność treści. Ze względu na transport QUIC/UDP, klasyczny MITM dla TLS (po TCP) nie ma zastosowania; nawet z certyfikatem użytkownika wgląd w treści HTTP jest ograniczony [1]. Analiza opiera się na metadanych (ALPN, SNI, strumienie, wolumeny, czasy) i korelacji zachowania.

Pinning. Nawet przy braku aktywnie zaimplementowanego pinningu, wybór QUIC ogranicza możliwość przechwycenia semantyki HTTP. W aplikacjach z rygorystycznym *certificate pinning* obserwowalność jest dodatkowo zawężona do metadanych (zob. [2]).

Replikowalność i zmienność. Wyniki dotyczą konkretnych wersji aplikacji i backendu, daty 2025-08-18, okna 13.7 min i scenariusza przewijania feedu.

3.8 Wariant porównawczy (HTTP/3 → HTTP/2)

Aby uzyskać wgląd w semantykę HTTP, zaplanowano wariant kontrolny z wymuszeniem *fall-backu* z QUIC na HTTP/2/TCP (blokada UDP/443 w sieci labowej) [1]. Porównywane będą: liczba żądań, rozkład kodów i metod HTTP (gdy odszyfrowalne), TTFB/czasy transferu, liczba i rola domen docelowych.

3.9 Artefakty i replikowalność

Zachowano .pcapng (plik zawiera zarówno pakiety, jak i klucze sesji), dziennik przebiegu (czas kroków), listę wersji aplikacji/OS oraz wyciągi agregatów (tabele 3.1 i 3.2). Schemat nazewnictwa plików: YYYYMMDD_HHMM_Instagram_runN_net={default|udp443_blocked}_vApp_vAndroid.pcapng.

3.10 Podsumowanie

Eksperyment pokazuje typowy dla nowoczesnych aplikacji wzorzec: dominację HTTP/3/QUIC dla treści (media), lekki kanał sterujący po TCP/5222 oraz okresowe aktywności w tle. W kontekście prywatności i bezpieczeństwa oznacza to, że analiza semantyczna wymaga wariantów kontrolnych (H3→H2) lub metod instrumentacyjnych; jednocześnie metadane ruchu pozwalają na wiarygodną charakterystykę wzorców komunikacyjnych i rozproszenia dostawców.

Bibliografia

- [1] M. Bishop, *HTTP/3*, RFC 9114, 2022. adr.: <https://www.rfc-editor.org/rfc/rfc9114>.
- [2] OWASP Mobile Security Testing Guide. „MASTG-TEST-0244: Missing Certificate Pinning in Network APIs.” (2025), adr.: <https://mas.owasp.org/MASTG/tests/android/MASVS-NETWORK/MASTG-TEST-0244/> (term. wiz. 17.08.2025).
- [3] *QUIC: A UDP-Based Multiplexed and Secure Transport*, RFC 9000, 2021. adr.: <https://www.rfc-editor.org/rfc/rfc9000>.
- [4] E. Rescorla, *The Transport Layer Security (TLS) Protocol Version 1.3*, RFC 8446, 2018. adr.: <https://www.rfc-editor.org/rfc/rfc8446>.
- [5] Wireshark Foundation. „Wireshark User’s Guide.” (2025), adr.: <https://www.wireshark.org/docs/> (term. wiz. 17.08.2025).

(2025)

Instytut Informatyki, Wydział Informatyki i Telekomunikacji
Politechnika Poznańska

Skład przy użyciu systemu L^AT_EX (Overleaf).